QUORIVIO

Manuale amministratore

Versione 0.1.0-dev · Build dev-20261024 · 24 ottobre 2026



Alessandro De Salvo · github.com/desalvo/quorivio

Le procedure riguardano le funzioni del codice di sviluppo; operazioni non verificate o pianificate sono indicate esplicitamente.

Indice

Architettura e responsabilità 4

Installazione e configurazione 5

CI/CD e controllo rilascio 6

Gestione operativa e GDPR 7

Appendici tecniche 8

Gestire le slide integrate 9

Approvazioni e impostazioni della piattaforma 10

Backup completo e limiti dei file 11

Checklist di prima installazione 12

PostgreSQL, migrazioni e protezione dei dati 13

Kubernetes: configurazione riproducibile 14

Sicurezza e GDPR: attività amministrative 15

CI/CD e problemi ricorrenti 16

Q&A; e parole: sicurezza e manutenzione 17

Upload in streaming e controlli 18

Controllo SMTPS e sicurezza degli account 19

Scansione antivirus degli allegati 20

MFA email con conferma e impostazioni atomiche 21

Configurazione OAuth GitHub e Facebook 22

Nuovi comandi e verifiche di sessione 23

Widget, gradimento e composizione delle pagine 24

Profili, collaborazione e gradimenti multipli 25

Editor grafico, formattazione e commenti 26

Importazione PDF/PPTX dal workspace 27

Sequenza pagine con trascinamento 27

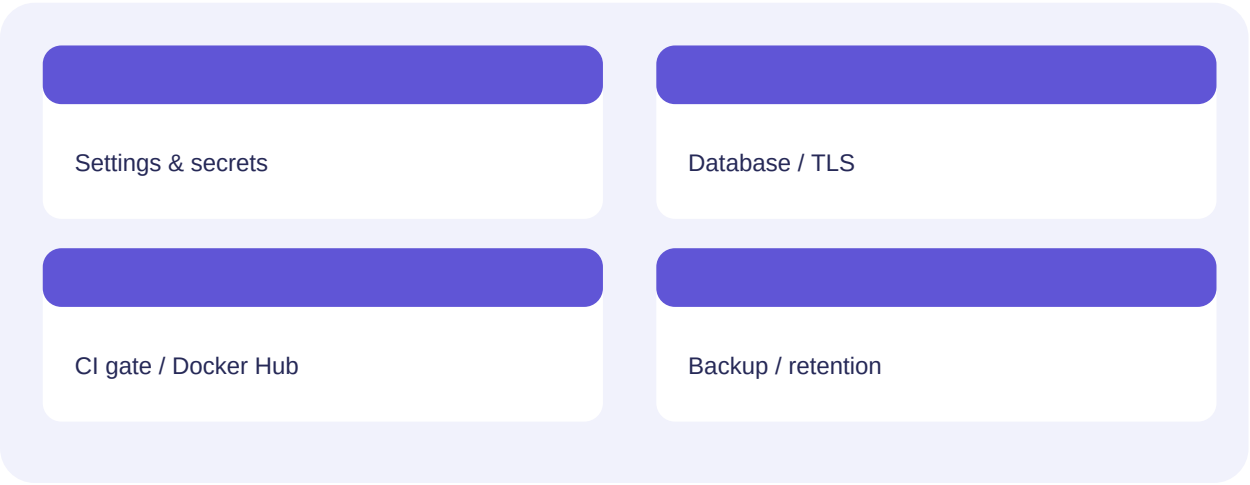
Canvas di posizionamento widget 28

Accesso federato OIDC (sperimentale) 29

Notifiche multi-replica e storage condiviso 30

Appendici e limiti noti 31

Architettura e responsabilità



Componenti

Frontend React/Vite, backend Node/Express, PostgreSQL come fonte autorevole, WebSocket per risultati in tempo reale, Kustomize e Compose per deployment. Redis/multi-replica non validati.

Ambito e limiti

Questa release è 0.1.0-dev. La CI verde confermata si riferisce al package precedente. Non rappresenta certificazione AgID o conformità GDPR verificata.

Installazione e configurazione

Repository e segreti

Recupera github.com/desalvo/quorivio. Configura PUBLIC_BASE_URL, DATABASE_URL e i segreti richiesti fuori dal controllo versione. Usa HTTPS, privilegi minimi e backup testati.

Docker e Podman

Consulta compose.yaml e .env.compose.example. Preparare i valori delle credenziali prima del deployment. Le prove complete rootless Podman restano da effettuare.

Wizard Kubernetes

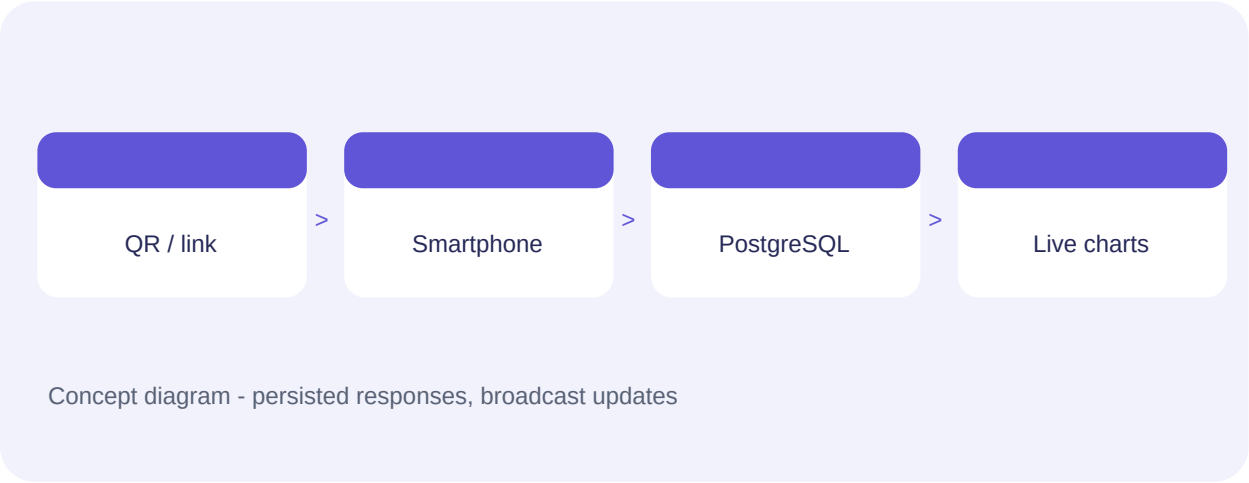
Esegui python3 tools/k8s_wizard.py --unattended --output ./k8s-generated --set host=quorivio.example.org. Il wizard crea manifest Kustomize separati e memorizza le modifiche ai default; non genera password.

Ingress

Configura ingressClassName per NGINX, HAProxy community o HAProxy Technologies. I vecchi controller HAProxy possono richiedere annotazioni legacy specifiche; evita di applicare contemporaneamente configurazioni incompatibili.

PostgreSQL

Il wizard supporta DB interno StatefulSet/PVC oppure DB esterno. Per DB esterno configura Secret DATABASE_URL e TLS verificato. Migrazioni maggiori PostgreSQL 17→18 richiedono procedura dedicata e backup: non sostituire soltanto l’immagine.



CI/CD e controllo rilascio

GitHub Actions

La pipeline esegue controlli di qualità, build immagini e scansione Trivy HIGH/CRITICAL prima del job di pubblicazione. Proteggi main con ruleset e check richiesti.

Docker Hub

Configura ambiente GitHub production, DOCKERHUB_USERNAME=desalvo e DOCKERHUB_TOKEN. Il push su main genera latest; il push di un tag v* genera il tag corrispondente. Non mettere credenziali nel repository.

Versionamento

Quorivio resta 0.1.0-dev. Nessun commit/push/tag/release deve essere automatizzato dall’assistente; solo GitHub Actions esegue la pubblicazione in seguito ad azioni dell’operatore autorizzato.

Gestione operativa e GDPR

Controlli operativi

Verifica liveness e readiness, log di applicazione, TLS e spazio disco PostgreSQL. Effettua test di ripristino, non soltanto backup. Una replica applicativa finché la sincronizzazione WebSocket multi-replica non sarà comprovata.

Privacy e conservazione

Configura informative, ruoli di titolare/responsabile, basi giuridiche e retention. Definisci procedure per accesso, cancellazione e data breach. I controlli tecnici non sostituiscono le valutazioni legali e organizzative.

Sicurezza

Segreti in secret manager/Kubernetes Secret esterni al repository; esegui scansioni dipendenze e container e conserva SBOM. Esegui prove di isolamento organizzativo e penetration test prima della produzione.

Appendici tecniche

Ripristino

Documenta RPO/RTO, esercita restore su ambiente separato, verifica consistenza dei dati e ripartenza della gestione sessioni prima di approvare il ripristino.

Problemi comuni

503 readiness: controlla DATABASE_URL/TLS e disponibilità PostgreSQL. Errore Docker Hub: controlla ambiente production e secret. Errori Ingress: verifica controller, DNS e TLS. Manca risultato live: controlla connessioni WebSocket.

Gestire le slide integrate

Prerequisiti

Il convertitore offline usa Poppler (pdfinfo/pdftoppm) e LibreOffice per PPTX. Eseguilo isolato dai servizi web, soprattutto con documenti non attendibili.

Migrazioni e media

Lo schema aggiunge il tipo attività slide e la tabella presentation_slide_assets. Verifica la migrazione su una copia del database prima della produzione. I file rimangono su storage persistente privato.

Sicurezza

Gli asset slide sono serviti pubblicamente solo quando la rispettiva pagina è corrente in una sessione attiva. Gli altri asset rimangono riservati. Non considerare la funzionalità collaudata fino ai test integrati.

Approvazioni e impostazioni della piattaforma

Gestire le approvazioni

Apri Amministrazione e carica utenti e impostazioni. Puoi creare un account con password temporanea di almeno 12 caratteri. Per gli utenti visualizzati scegli ruolo e approvazione, poi salva. I presentatori non approvati non possono creare sessioni. Controllare la gestione account esistenti con test end-to-end prima dell’uso.

URL pubblica e conservazione

Imposta un indirizzo HTTPS assoluto usato nei QR e nei link delle sessioni. Configura i giorni di conservazione globale dalla chiusura (valore predefinito 60). L’aggiornamento degli URL non rende automaticamente validi vecchi QR già scaricati.

Credenziali iniziali

La password demo 000000 è ammessa solo esplicitamente in ambiente NON production e deve essere cambiata al primo accesso. In produzione configura password forte iniziale. Le nuove registrazioni non sono attive fino ad approvazione admin.

Non ancora disponibili

SMTP/SMTPS con email di prova, MFA via email/TOTP, provider SSO, export XLSX e gestione documenti caricati sono in roadmap; non configurarli come se fossero completati.

Backup completo e limiti dei file

Backup e restore

Il backup completo del database e degli allegati non e ancora disponibile via UI. Usare procedure PostgreSQL esterne affidabili, backup coerenti dello storage e prove di ripristino in un ambiente isolato. Non caricare dump provenienti da fonti non attendibili.

Massimo upload

Il valore iniziale e 100 MB. La voce max_upload_mb e configurabile nell'API amministrativa: il wizard Kubernetes supporta --set max_upload_mb=100 e genera le annotazioni NGINX e HAProxy Technologies. Il cambio di impostazione nell'app non modifica automaticamente un Ingress esistente.

Funzioni non concluse

L'upload reale di file, la scansione malware, le quote, il ripristino completo automatico e l'interfaccia dedicata rimangono da implementare e testare.

Checklist di prima installazione

Sicurezza prima dell’avvio

Prepara DNS pubblico e certificato TLS valido. Configura credenziali robuste, database PostgreSQL, segreti fuori dal repository, storage persistente e accessi amministrativi limitati. La password demo 000000 richiede opt-in non produzione; non esporla in Internet.

Configurazione indirizzo esterno

Nell’area Amministrazione imposta la URL HTTPS effettiva del servizio. Questa URL viene impiegata nella generazione degli inviti di sessione. Dopo una modifica, richiedi ai presentatori di rigenerare e sostituire i QR già scaricati.

Registro delle approvazioni

L’autoregistrazione non equivale ad autorizzazione. Controlla identità e necessità del ruolo prima di approvare utenti o presentatori. Revoca prontamente gli accessi non più necessari e documenta chi ha autorizzato l’account.

Verifica di disponibilità

Controlla /api/health/live e /api/health/ready, PostgreSQL e certificati; fai un test con presentatore e browser anonimo. La CI è stata confermata verde su un cumulativo precedente, non sull’ultima modifica.

PostgreSQL, migrazioni e protezione dei dati

Installazione interna

Il wizard può generare StatefulSet e PVC PostgreSQL 18.6. Per dati reali pianifica ridondanza, storage affidabile, backup e processi di aggiornamento. Un singolo StatefulSet non costituisce alta disponibilità.

Database esterno

Imposta postgres_mode=external e configura host, porta, SSL verify-full, credenziali in Kubernetes Secret. Valida la catena CA e l'identità del server prima del go-live. Non includere stringhe DATABASE_URL nei manifest versionati.

Migrazioni

Esegui le migrazioni del database in una finestra controllata e su copia di prova con dataset realistico. Prima di passare da PostgreSQL 17 a 18 effettua una migrazione maggiore compatibile: cambiare l'immagine container non migra automaticamente i dati.

Backup e ripristino

Il backup integrale e il restore via UI non sono implementati. Fino ad allora usa strumenti PostgreSQL supportati e backup sincronizzati di eventuali file esterni; verifica il ripristino completo in ambiente isolato. Documenta RPO, RTO, cifratura e accesso ai backup.

Kubernetes: configurazione riproducibile

Generazione standard

Esegui python3 tools/k8s_wizard.py --unattended --output ./k8s-generated --set host=quorivio.example.org --set max_upload_mb=100. Conserva solo i valori custom rispetto ai default; non inserire password. Valida le risorse prima di applicarle.

Ingress NGINX e HAProxy

Seleziona il controller effettivamente installato. ingressClassName e annotazioni legacy HAProxy differiscono tra controller: controlla manualmente i manifest generati. L’annotazione NGINX proxy-body-size limita la dimensione del body; il backend deve applicare limiti equivalenti.

Post-installazione

Usa kubectl kustomize per ispezionare la generazione e kubectl apply -k soltanto dopo convalida. Verifica DNS, TLS, limiti CPU/memoria, Secret esistenti, mount dei volumi e log di readiness. Multi-replica WebSocket resta da collaudare.

Gestione delle modifiche

Rigenera i manifest dopo aggiornamenti a URL, classe ingress o dimensione upload. Cambiare un valore nel pannello amministrativo non modifica automaticamente il controller Kubernetes. Conserva il diff dei manifest e predispone rollback.

Sicurezza e GDPR: attività amministrative

Data protection by default

Decidi basi giuridiche e ruoli di titolare/responsabile del trattamento, documenta informative, categorie di dati, fornitori esterni e tempi di conservazione. La piattaforma offre controlli tecnici parziali e non può da sola certificare la conformità.

Conservazione

La retention globale iniziale delle sessioni chiuse è 60 giorni. Verifica le regole locali prima di modificarla: audit e backup potrebbero richiedere policy separate. Controlla periodicamente che la pulizia schedulata operi sui dati previsti.

Cookie e identità

I partecipanti anonimi usano un cookie tecnico e uno pseudonimo. La finestra di conferma dei cookie necessari va distinta da un consenso per usi opzionali. Le registrazioni locali richiedono approvazione; SSO e MFA sono disponibili; SMTP/SMTPS può essere configurato nelle impostazioni server. Le integrazioni esterne richiedono credenziali e verifica operativa.

Accesso ai log e incidenti

Proteggi log e audit evitando password, token e risposte sensibili. Predisponi escalation incidenti, rotazione delle credenziali, revoca delle sessioni e notifiche richieste dal GDPR quando applicabili. Esegui test di ripristino e tabletop exercise.

CI/CD e problemi ricorrenti

GitHub e Docker Hub

Il workflow include gate di qualità, build container e Trivy HIGH/CRITICAL. Pubblica desalvo/quorivio:latest dai push main e il tag versionato dai tag, solo dopo gate e protezioni di production. I secret Docker Hub sono nell’ambiente production.

La build fallisce per npm

Controlla che package-lock.json sia presente e coerente se usi npm ci. Il workflow precedente ha disabilitato la cache perché mancava il lockfile; non disabilitare controlli per ottenere un esito verde.

Trivy segnala CVE

Leggi il percorso di origine della vulnerabilità e aggiorna/elimina il componente interessato. Il runtime non dovrebbe includere gli strumenti npm di compilazione; non escludere HIGH/CRITICAL senza motivazione e approvazione.

Funzioni ancora mancanti

I servizi esterni di login e posta, la convalida del cluster multi-replica e i collaudi browser end-to-end richiedono ancora verifica. La CI non sostituisce il collaudo operativo.

Q&A e parole: sicurezza e manutenzione

Persistenza

Lo schema PostgreSQL contiene audience_words, audience_questions e audience_question_votes. Le tabelle sono legate alle sessioni e vengono rimosse insieme alla sessione via CASCADE. Applicare lo schema prima di avviare il backend aggiornato.

Autorizzazioni

L’invio è ammesso solo con cookie partecipante valido nella sessione attiva e attività aperta. Approvazione, rifiuto e statistiche complete richiedono l’autenticazione di un presentatore autorizzato.

GDPR e conservazione

Le parole e le domande sono contenuti generati dal pubblico: predisporre informativa, moderazione e retention, evitando raccolte non necessarie di dati personali. Restano necessari test di concorrenza e abuso.

Upload in streaming e controlli

Caricamento file

Il caricamento usa scrittura progressiva su volume privato e verifica firma, lunghezza e limite di 100 MB; non lasciare il browser prima della conferma. La scansione antivirus è inclusa nel deployment Compose/Helm, ma lo storage condiviso resta da integrare.

Controllo SMTPS e sicurezza degli account

Configurazione SMTP

Aprire Impostazioni server e compilare host, porta SMTPS, account, password e mittente. Le credenziali sono cifrate nel database; la password non viene restituita al browser. Verificare la configurazione e inviare una mail di prova.

Test e limitazioni

SMTPS richiede TLS con certificato valido. STARTTLS non è abilitato in questa configurazione. Reset password via email e codici di recupero MFA sono implementati, ma la consegna effettiva deve essere collaudata. Il servizio non è certificato AgID o GDPR.

Chiave AUTH_SECRET

Conservare una chiave segreta stabile: il suo cambiamento rende illeggibili i segreti MFA cifrati. Valutare una migrazione protetta prima della rotazione.

Scansione antivirus degli allegati

Attivazione ClamAV

Avviare Quorivio via Compose/Helm: lo stack include automaticamente ClamAV su rete privata; conserva e aggiorna le firme, e imposta QUORIVIO_AV_REQUIRED=true. Senza scanner disponibile il backend deve rifiutare gli upload invece di considerarli sicuri.

Verifica e operatività

Eseguire prove reali con un file di test innocuo e con il pattern di prova EICAR in un ambiente autorizzato. Verificare i log, l’eliminazione degli allegati rifiutati e l’assenza di record nel database. Questo controllo non è ancora collaudato su un servizio ClamAV reale.

Limitazioni

La scansione antivirus non sostituisce la validazione MIME, le politiche GDPR o l’isolamento della conversione documenti. Lo scanner non è incluso nell’installazione di default. Consultare docs/ANTIVIRUS_UPLOADS.it.md.

MFA email con conferma e impostazioni atomiche

Iscrizione MFA email

In Sicurezza / MFA, inserire la password e richiedere il codice di iscrizione. Il fattore email NON diventa attivo finché il codice di sei cifre ricevuto nella casella di posta non viene confermato entro dieci minuti. TOTP resta indipendente.

Limiti e disattivazione

Il backend accetta al massimo cinque errori per codice e tre richieste d’iscrizione al minuto per account. La conferma o la disattivazione revoca le sessioni precedenti, richiedendo un nuovo accesso.

Impostazioni server e foto

Le modifiche combinate a URL pubblico, retention e limite upload vengono validate integralmente e salvate in un’unica transazione. Le fotografie private vengono sostituite con blocco per utente e i file precedenti rimossi. I collaudi multi-replica e browser restano aperti.

Procedura di accettazione

Provare SMTP reale, codice errato/scaduto, rinnovo dopo revoca, login TOTP/email indipendenti, aggiornamenti amministrativi con valori non validi e collisioni di importazione .quorivio. La CI aggiunge un test HTTP PostgreSQL, ma la prima esecuzione sulla nuova revisione è ancora da verificare.

Configurazione OAuth GitHub e Facebook

Credenziali

Imposta OAUTH_GITHUB_CLIENT_ID, OAUTH_GITHUB_CLIENT_SECRET, OAUTH_GITHUB_REDIRECT_URI, e i corrispondenti OAUTH_FACEBOOK_*. Registrare callback HTTPS /api/auth/social/<provider>/callback.

Vincoli

Non è consentito il collegamento silenzioso tramite email; serve un account locale approvato già autenticato. Lo stato OAuth è locale al processo: usare una sola replica fino allo storage condiviso e verificare permessi/app provider.

Nuovi comandi e verifiche di sessione

Import/export e sicurezza

I presentatori approvati possono duplicare sessioni e trasferirne le sole definizioni JSON. L’amministratore deve distinguere queste esportazioni dal backup completo dell’istanza, che è ancora da sviluppare.

Collaborazione e audit

Verificare che ogni co-presentatore appartenga alla stessa organizzazione e abbia ruolo e approvazione validi. Registrare e riesaminare le invalidazioni di risposte. Non equiparare una semplice modifica live alla cancellazione dei dati storici.

Controlli di messa in esercizio

La CI verde del package precedente non copre le nuove schermate. Richiedere test integrazione API/PostgreSQL, verifica browser, isolamento di organizzazioni e scansione delle dipendenze prima della promozione a produzione.

Widget, gradimento e composizione delle pagine

Identificazione del manuale

Versione applicativa: 0.1.0-dev. Build documentale: dev-20261024. Il tag Git non viene riportato nei manuali; una nuova revisione o un tag non richiedono rigenerazione se interfacce e build documentale non cambiano.

Widget disponibili

La palette comprende gradimento da 0 a 10, reazioni con emoticon, blocco testo, divisore, timer indicativo e richiamo QR. I widget non sostituiscono la raccolta delle risposte di quiz e sondaggi.

Istruzioni presentatore

Apri una sessione, scegli Layout pagina per una domanda, seleziona + rating (oppure un altro widget), personalizza l’etichetta, riordina gli elementi trascinandoli o tramite le frecce e premi Salva layout. La configurazione viene salvata per attività. Il salvataggio non elimina risposte pregresse.

Istruzioni partecipante

Entra usando il QR e lo pseudonimo. Quando una pagina include la scala di gradimento, seleziona un numero tra 0 e 10. Si registra una sola valutazione per partecipante e attività; non è una risposta al quiz. Le emoticon continuano a essere gestite separatamente.

Statistiche

Il presentatore seleziona Gradimento 0–10 nella vista sessione e consulta media e numero di valutazioni complessive e per pagina. Gli estremi e la distribuzione sono disponibili tramite API autorizzata; non esporre i dati identificativi sullo schermo pubblico.

Limitazioni

L’editor a coordinate permette spostamento, ridimensionamento, rotazione e controlli da tastiera; la precisione e i gesti touch devono ancora essere collaudati su dispositivi reali. Gli elementi timer e QR hanno comportamenti dipendenti dalla pagina e non sono equivalenti a un PowerPoint interattivo.

Profili, collaborazione e gradimenti multipli

Apertura dei progetti

Il workspace distingue Autore / proprietario da Invitato alla collaborazione direttamente nell’elenco delle sessioni.

Profilo del presentatore

Carica il profilo nell’area Profilo presentatore, imposta il nome pubblico e un URL HTTPS della foto, quindi salva. Il caricamento diretto di PNG, JPEG e WebP fino a 5 MiB è disponibile: il file sostituito viene eliminato; verificare sempre l’autorizzazione al ritratto e la persistenza del volume condiviso.

Widget profilo

Apri Layout pagina, aggiungi + profile, seleziona il presentatore della sessione e salva. Ripeti per più profili e usa Rimuovi per eliminare singoli widget.

Gradimenti indipendenti

Aggiungi più widget rating con identificativi diversi. Scegli Domanda, Quiz, Sessione o Presentatore; nel caso del presentatore seleziona la persona. Un partecipante può votare ciascun widget una sola volta.

Statistiche e limiti

Il report del presentatore include media e numero di valutazioni per widget. Il collegamento quiz fa attualmente riferimento all’attività; la gestione di quiz composti resta da completare. È necessaria la prova della migrazione PostgreSQL.

Editor grafico, formattazione e commenti

Opzioni del widget

Nel pannello Layout pagina aggiungi più widget, imposta un titolo per ogni gradimento, aggiungi una descrizione facoltativa e apri Stile e animazioni per scegliere font, dimensione 10–96, colore, grassetto, corsivo, sottolineato, barrato e animazione fade/slide.

Modifica del testo

Fai doppio clic nel campo titolo per selezionarlo e modificarlo; salva il layout per rendere persistente la modifica. Trascina gli oggetti per riordinarli o usa ↑ e ↓.

Gradimento con commento

Ogni widget rating richiede un titolo. Il partecipante può aggiungere un commento facoltativo fino a 1000 caratteri e selezionare il punteggio 0–10. Il commento resta privato e non viene mostrato negli aggregati pubblici.

Domanda come widget

È possibile aggiungere un widget domanda con modalità singola, multipla, libera o file. Nella build corrente il widget aggiuntivo è un blocco visuale: non dispone ancora di invio indipendente rispetto alla domanda principale.

Limiti

La sequenza delle attività non ha ancora un canvas grafico completo. Il posizionamento libero nel canvas è disponibile in modalità sperimentale; non è completato l’editor di media per singolo widget. Verificare PostgreSQL/browser prima della produzione.

Importazione PDF/PPTX dal workspace

Prerequisiti

La conversione diretta è sperimentale e disabilitata per impostazione predefinita. Richiede Python 3, Poppler e LibreOffice per i file PPTX, con script di conversione installato. Non abilitare su server di produzione senza confinamento del worker in un container dedicato.

Procedura presentatore

1. Apri una sessione di cui sei autore o collaboratore. 2. Nella sezione Allegati scegli Importa direttamente PDF/PPTX. 3. Seleziona un file fino a 100 MiB. 4. Attendi il risultato dell’operazione. 5. Controlla le pagine slide nella sequenza e apri la prima per il pubblico.

Controlli e limiti

Fino a 200 pagine. Le diapositive sono convertite in immagini; transizioni, video e animazioni non vengono mantenuti. L’importazione non è disponibile se QUORIVIO_ENABLE_CONVERTER non è true. Il processo attuale è separato tramite subprocess, ma non ancora isolato come worker dedicato.

Gestione degli errori

HTTP 503: convertitore non configurato. HTTP 415: formato non supportato. HTTP 413: documento troppo grande. HTTP 500: consultare log riservati e dipendenze del convertitore; la transazione delle slide viene annullata.

Sequenza pagine con trascinamento

Nel workspace apri la sessione: trascina una riga della sequenza su un’altra pagina per cambiarne la posizione. In alternativa usa i pulsanti Su/Giù, accessibili da tastiera. Premi Duplica pagina per aggiungere un nuovo oggetto senza risposte precedenti. Il salvataggio mantiene gli identificativi delle pagine, le risposte e la pagina correntemente aperta. In una sessione chiusa il riordino è disabilitato.

Il riordino richiede un browser con HTML5 drag-and-drop e la connessione al server. In caso di errore la sequenza viene ricaricata dal backend.

Canvas di posizionamento widget

Utilizzo

Apri Layout pagina. Nel canvas grafico trascina i widget dal loro interno, ridimensionali dai bordi, ruotali con la maniglia circolare e modifica il titolo con doppio clic. Il canvas bianco 16:9 dispone di righelli e di modalita a schermo intero.

Rimozione e persistenza

Il pulsante Rimuovi elimina solo il widget selezionato. Premi Salva layout per registrare le coordinate percentuali nel database; alla riapertura la pagina mantiene la disposizione salvata.

Tastiera e accessibilità

L’elenco ordinabile con frecce e i menu di proprietà restano disponibili senza drag-and-drop. La manipolazione spaziale avanzata con tastiera e l’accessibilità completa del canvas richiedono ulteriori collaudi.

Avvertenze

Il comportamento su browser mobili, la migrazione PostgreSQL e le modifiche ai layout sono in attesa di collaudo. Domande per argomento: ogni widget consente al presentatore di consultare 10 domande alla volta.

Accesso federato OIDC (sperimentale)

Disponibilità

L’accesso Google, generic OIDC o tramite provider OIDC custom compare soltanto se il gestore configura tutti i parametri HTTPS. GitHub e Facebook sono disponibili come flussi OAuth2 sperimentali; SAML non è ancora integrato.

Collegamento identità

Accedi con l’account locale approvato, quindi usa Collega nella pagina del profilo. Autenticati presso il provider e verifica che la pagina confermi il collegamento. Non è sufficiente che gli indirizzi email coincidano.

Login federato

Dopo il collegamento, dalla pagina di login seleziona il provider configurato. Chi ha MFA TOTP attivo deve continuare ad accedere con password e codice MFA locali.

Limitazioni di produzione

Occorrono prove con l’identity provider reale, la migrazione PostgreSQL, state condiviso multi-replica e security review. Leggi docs/OIDC_SSO.it.md e non considerare questo flusso certificato o production-ready.

Notifiche multi-replica e storage condiviso

Sincronizzazione

Il backend usa PostgreSQL LISTEN/NOTIFY per propagare aggiornamenti WebSocket tra istanze; i payload contengono solo identificativi, non dati personali.

Archiviazione

Più repliche richiedono un PVC ReadWriteMany realmente supportato dal cluster. Helm può usare un claim esistente.

Limitazioni

La limitazione HTTP usa finestre PostgreSQL condivise, ma stato OAuth/OIDC e sessioni di provider richiedono prove multi-replica; evitare di distribuire senza convalida. Non sono stati eseguiti collaudi cluster o browser.

Appendici e limiti noti

Stato: sviluppo. Prima della produzione consultare docs/DEVELOPMENT_STATUS.md, docs/GDPR.it.md e docs/SECURITY.it.md.

I diagrammi sono ricostruzioni illustrative dei flussi, non screenshot acquisiti da browser.